

Relatório Técnico de Análise de Malware

Sumário

1. Apresentação
2. Resumo Executivo
3. Montagem do Laboratório e Ferramentas utilizadas
4. Identificação da ameaça
5. Vetores de Infecção
6. Resultados da análise
    a. Análise estática
    b. Análise dinâmica
7. Mapeamento do MITRE ATT&CK
8. Impacto potencial
9. Medidas de mitigação
10. Conclusão
11. Referências

1. Apresentação

Malware Investigado: Proteus malware

Data: 25/09/2025

Analista Responsável: Mauricio Robert

Organização: Faculdade Impacta

2. Resumo Executivo

O malware Proteus teve sua primeira aparição em sites na deep-web como um Malware-as-a-service(MaaS) em 2017, sua função principal foi roubo de credenciais, dados financeiros e informações sensíveis. Suas capacidades dentro desta versão são downloader e backdoor. Seus autores são desenvolvedores anônimos e utilizado por cybers criminosos.

3. Montagem do laboratório e ferramentas utilizadas

A análise foi conduzida em um laboratório em uma V.M. isolado e controlado, seguindo as boas práticas de segurança.

Ferramentas utilizadas:

ISO: https://archive.org/download/win-10-1803-english-x-64/Win10_1803_English_x64.iso

Estática: PEStudio, Virus Total, Underground, IDA e CAPA

Dinâmica: Procmon, Process Explorer, Wire Shark e TCPView

Assinatura: Windows Defender history

4. Identificação da ameaça

- **Nome da Família:** Proteus Malware
- **Classificação:** Downloader / Backdoor
- **Hash SHA256:** D23B4A30F6B1F083CE86EF9D8FF434056865F6973F12CB075647D013906F51A2
- **Origem da Amostra:** Capturada em ambiente controlado : Virtual Machine
- **Primeira Captura:** 28/11/2016
- **Nível de risco:** Alto, devido à versatilidade, persistência e seu impacto

5. Vetores de infecção

Como neste caso estamos estudando-o, baixamos no repositório TheZoo no GitHub.

Porém em casos reais ele poderia se propagar por meio de:

- **Phishing (e-mails maliciosos)** → anexos infectados ou links que baixam o malware.
- **Software pirata/crackeado** → instaladores falsos que instalam o Proteus junto.
- **Exploração de vulnerabilidades** → uso de falhas em sistemas ou apps desatualizados para executar o código malicioso.

6. Resultados da análise

- **Análise estática:**

Arquivo: gchrome.exe (falso Google Chrome)

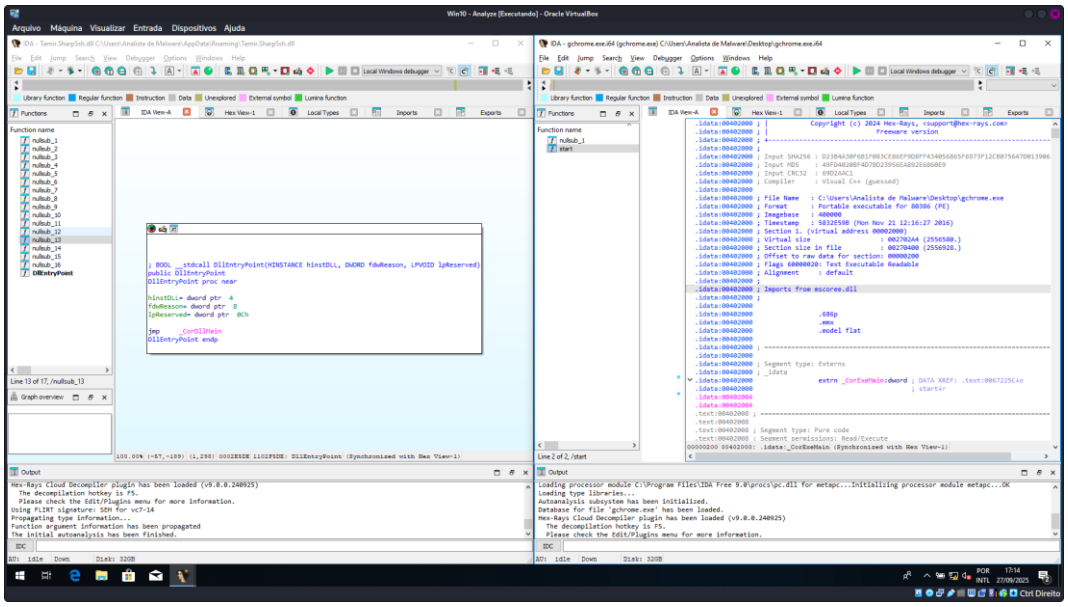
Formato: PE .NET, 32-bit

Hash256: D23B4A30F6B1F083CE86EF9D8FF434056865F6973F12CB075647D013906F51A2

Entropia: 7.82 (alta)

Detecção Virus Total: 59/69

Imports principais: mscoree.dll (executa assembleis .NET)



Indícios que o malware puxa o mscoree.dll

Evidências de obfuscação e recursos:

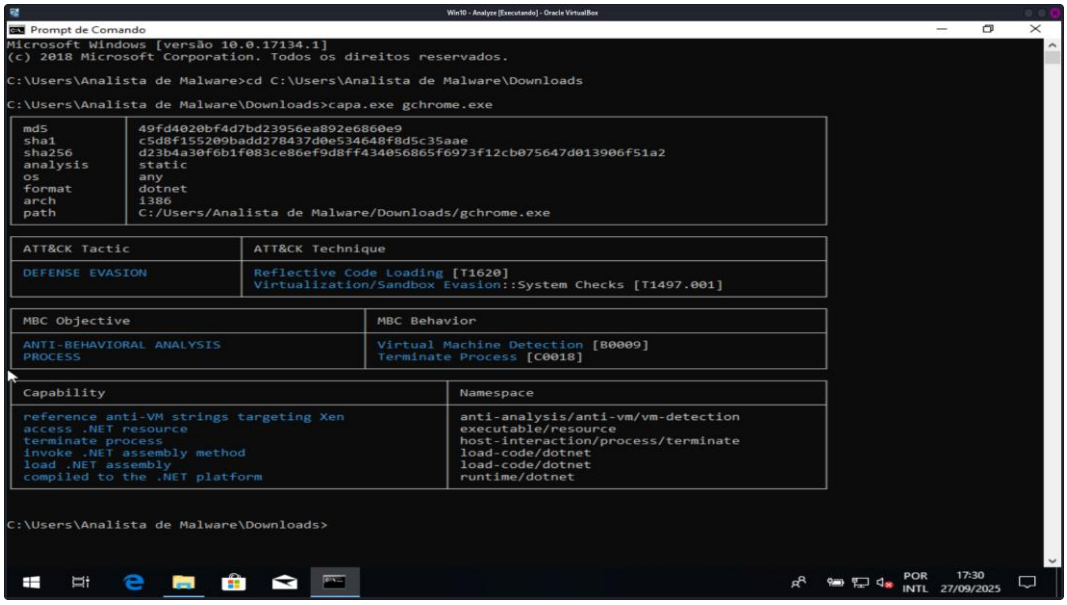
- Strings repetidas e nomes aleatórios -> indícios de obfuscadores e recursos embarcados.
- Utiliza muitos recursos PNG embutidos -> possibilidades de payload embutido (estenografia).
- Presença de chaves/salts e identificadores estranhos -> sugerindo criptografia dinâmica na parte do código.

Funcionalidades observadas

- **APIs de criptografia .NET:** uso de CryptoStream, CreateDecryptor, MemoryStream, ToArray.
- **Reflexão e carregamento dinâmico:** chamadas a GetExportedTypes, GetMethods, MethodInfo.

Capacidades

- Anti-VM / Anti-sandbox
- Encerramento de processos
- Acesso e invocação de recursos/métodos .NET.
- Carregamento de assemblies adicionais em runtime.

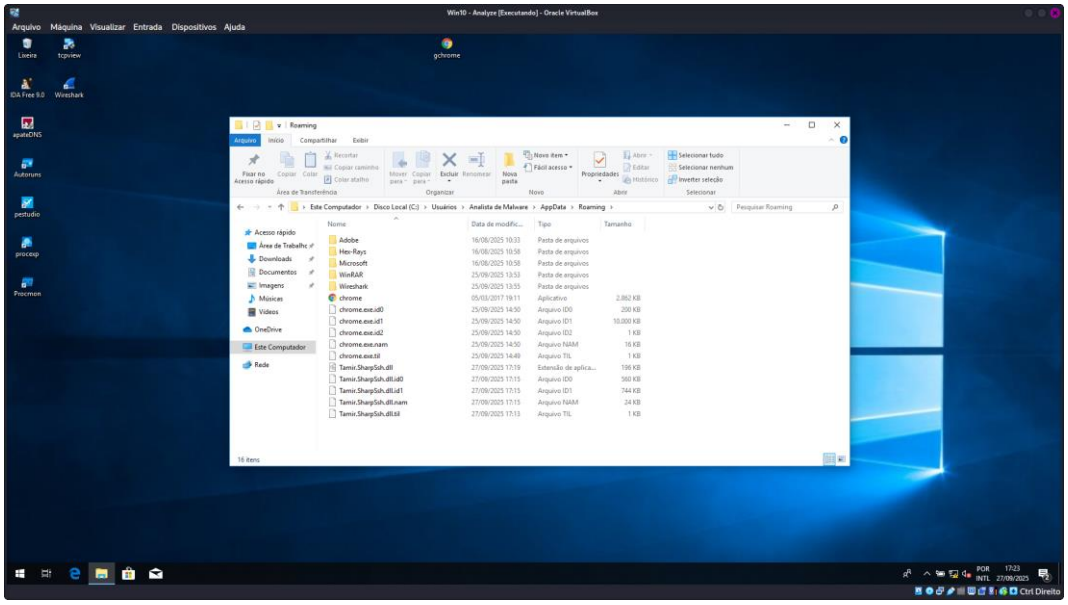


Relatório do CAPA

- **Análise Dinâmica:**
  - ❖ **Localização do binário após inicialização do malware**

    Caminho: C:\Usuários\AnalistadeMalware\AppData\Roaming\chrome.exe
    Tamanho: 2,79 MB
    Nome do arquivo original: gchrome.exe
    Data de modificação: 05/03/2017
    Descrição: Google Chrome
    Versão: 55.0.2840.99 (Adulterado)

    A presença do binário em AppData\Roaming é um forte indicativo de que se trata de um aplicativo malicioso. Além disso, ao executar o chrome.exe localizado nessa pasta, o aplicativo **não inicializa o Google Chrome**, confirmando que o binário não é autêntico.

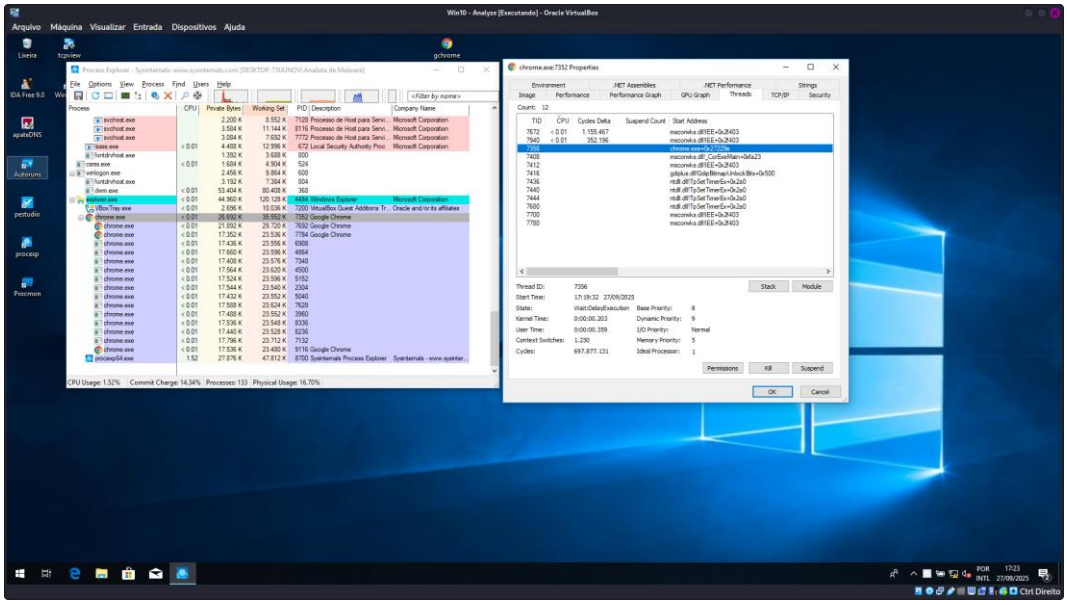


Chrome modificado

- **Processos e Threads**

  Durante a execução do Process Explorer, ao acessar as propriedades do binário modificado, pode-se notar múltiplas threads associados a ele, como:

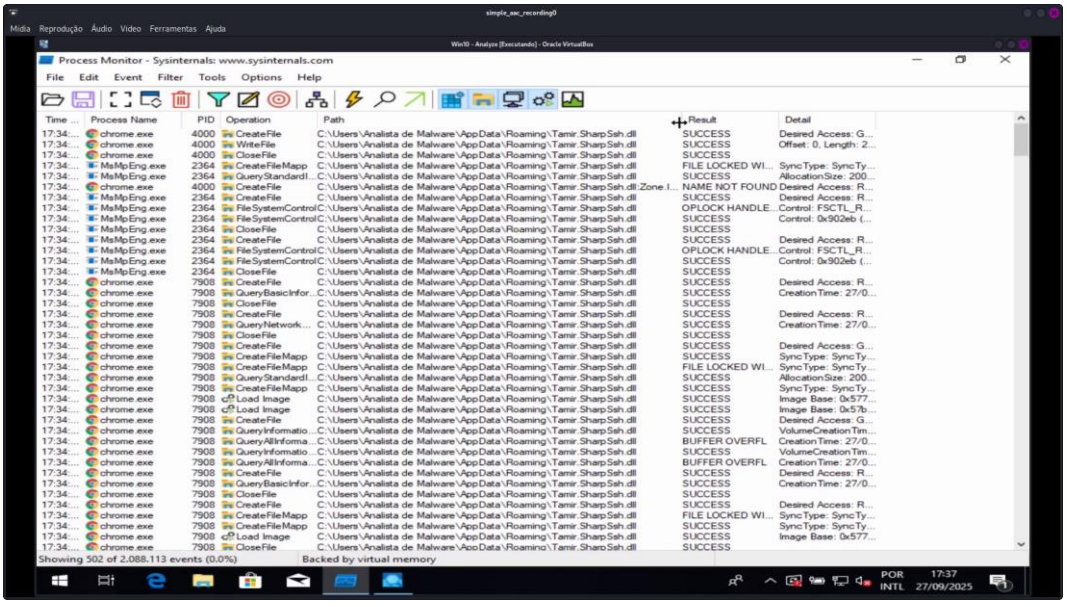
  - **chrome.exe+0x27229e** → Indica execução direta de código no processo camuflado.
  - **mscorwks.dll!EE+0x2f403** → Mostra interação com o **.NET Runtime**.
  - **ntdll.dll!TpSetTimerEx+0x2a0** → Indica manipulação de timers
  - **gdiplus.dll!GdipBitmapUnlockBits** → Uso da GDI+ indica manipulação de imagens. A análise de *strings* mostra várias referências a **.png**, sugerindo que o malware pode empregar imagens para **ofuscação ou esteganografia**.
  - **combase.dll!CoDecrementM...** → Sugere interação com **COM Objects**, típico em malware que tenta integrar com o sistema.



Processos e Threads do binário infectado

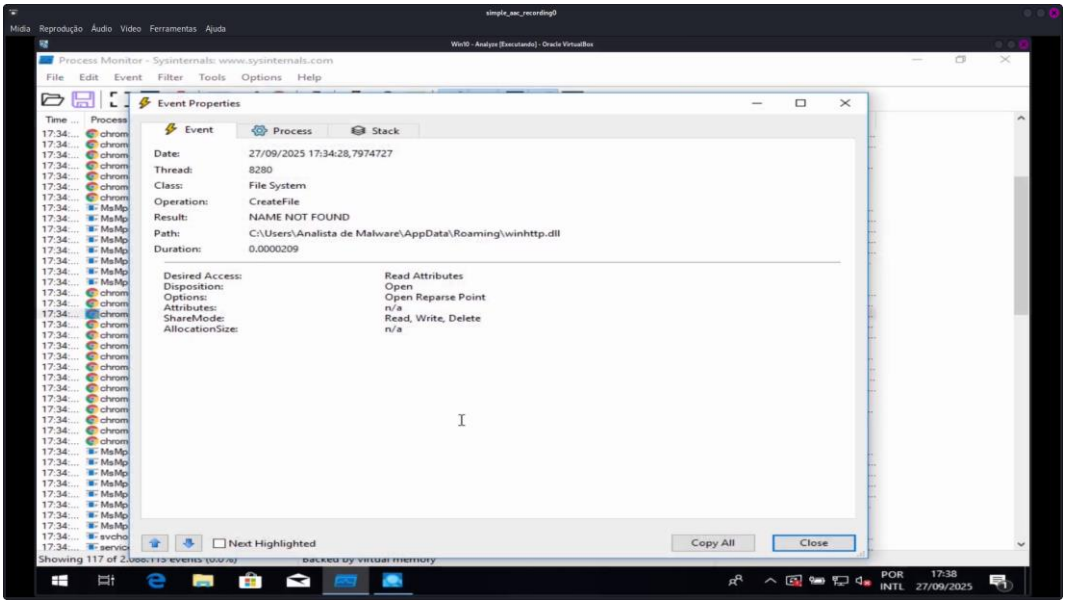
- **Funcionalidades das DLLs**

Tamir.SharpSsh.dll -> Sua origem é biblioteca de terceiros para .NET que implementa os protocolos **SSH/SFTP/SCP**; no contexto do malware, provavelmente é usada para **estabelecer conexões remotas seguras** e **exfiltrar dados** por canais criptografados.



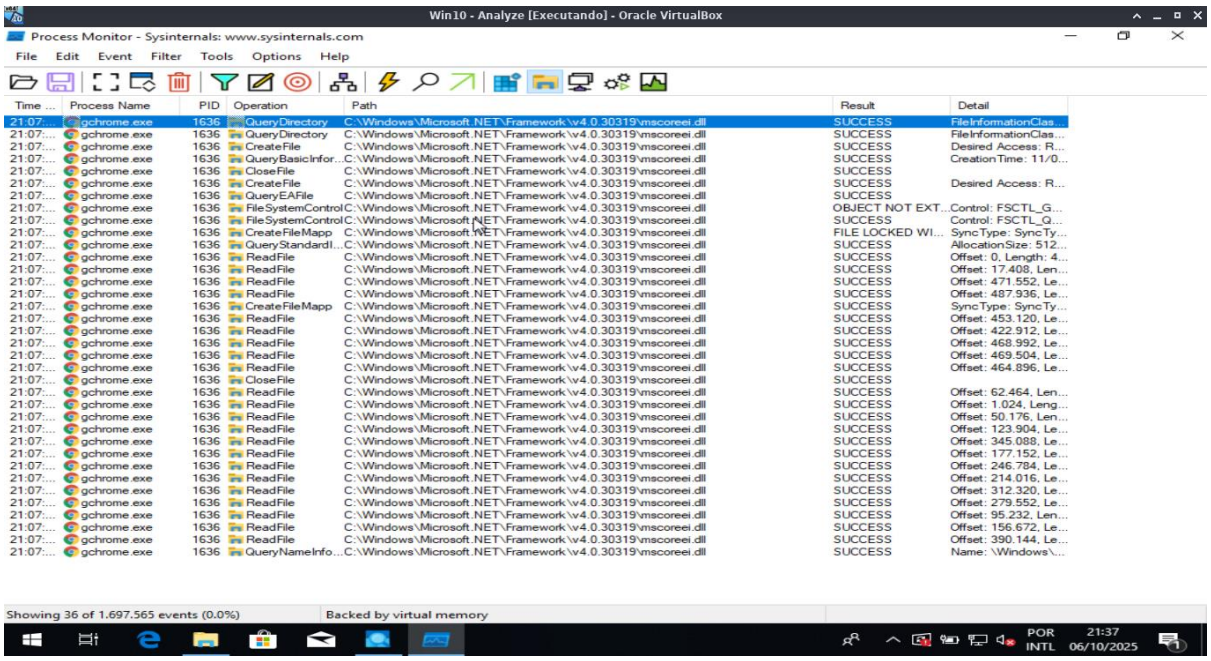
Tamir.SharpSsh.dll encontrado

Winhttp.dll -> Sua origem é uma biblioteca legitima do Windows utilizada para comunicações HTTP; no contexto do malware provavelmente é utilizada para redirecionar chamadas de rede, interceptação de tráfego HTTP/HTTPS e estabelecimento de comunicação C2



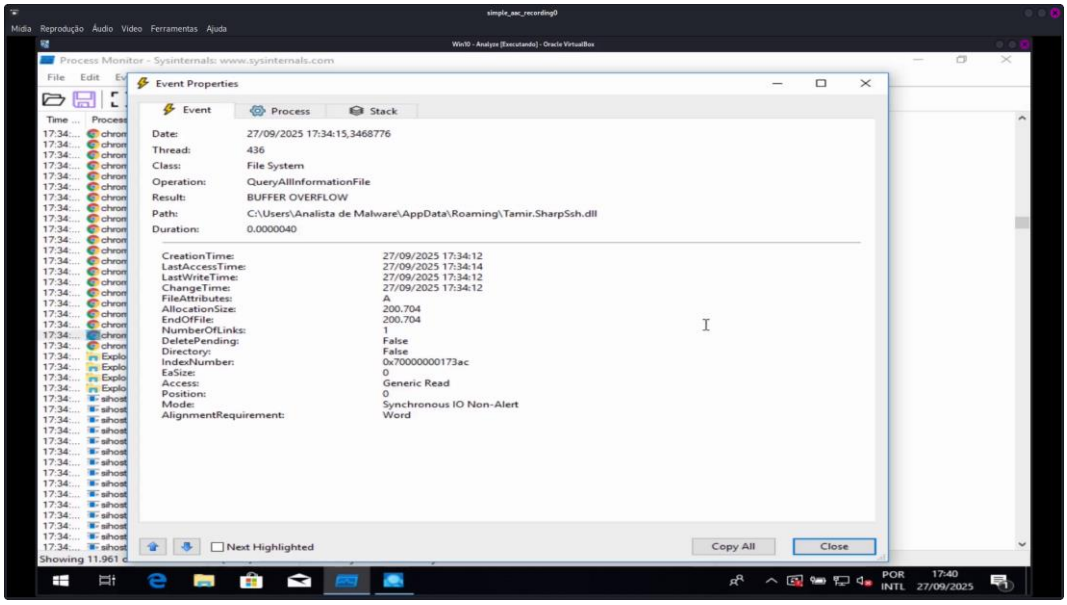
winhttp.dll encontrada

mscoreei.dll -> A *mscoree.dll* é um componente legítimo do Windows responsável por iniciar a CLR para aplicações .NET. Essa ameaça usam um nome quase idêntico, como mscoreei.dll (com um "i" extra), como técnica de *stealth* para se disfarçar.



❖ **Buffer Overflow**

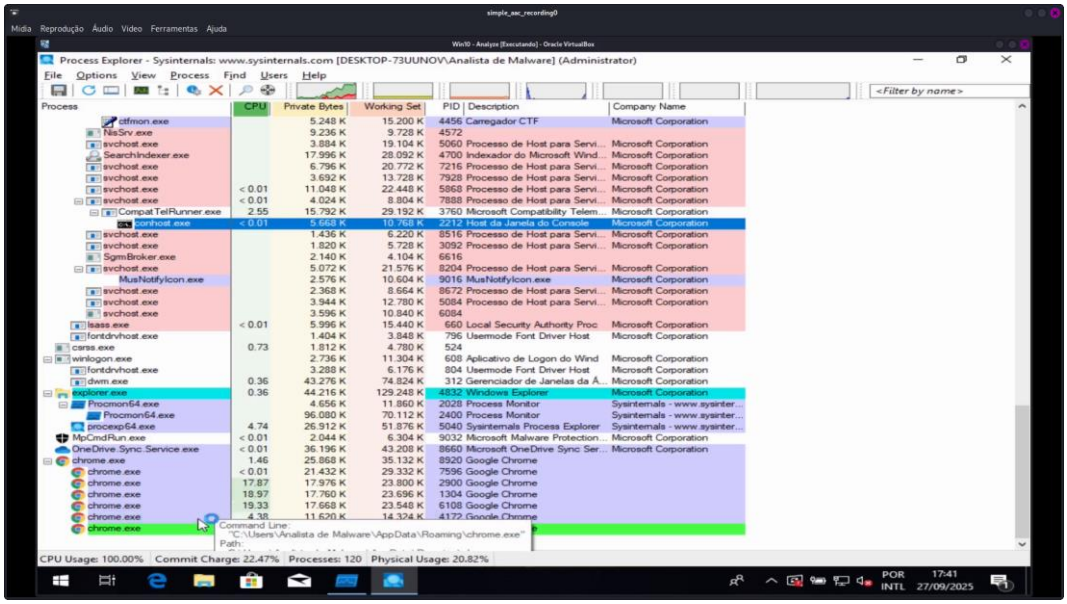
Durante a análise dentro do procmon pode-se observar o malware utilizando o uso inadequado da memória da máquina, caracterizando como técnicas de **buffer overflow**.



Buffer Overflow detectado

❖ **Replicação e Diferenciação**

No **Process Explorer (executado como Administrador)** observou-se que o malware se replicou em múltiplas instâncias. Ao abrir o Process Explorer em modo não-administrador, algumas dessas instâncias **não ficam visíveis**, indicando que o malware emprega técnicas para ocultar processos de visões com privilégios reduzidos. A instância superior corresponde ao processo legítimo/host real; a instância inferior é o **gchrome**

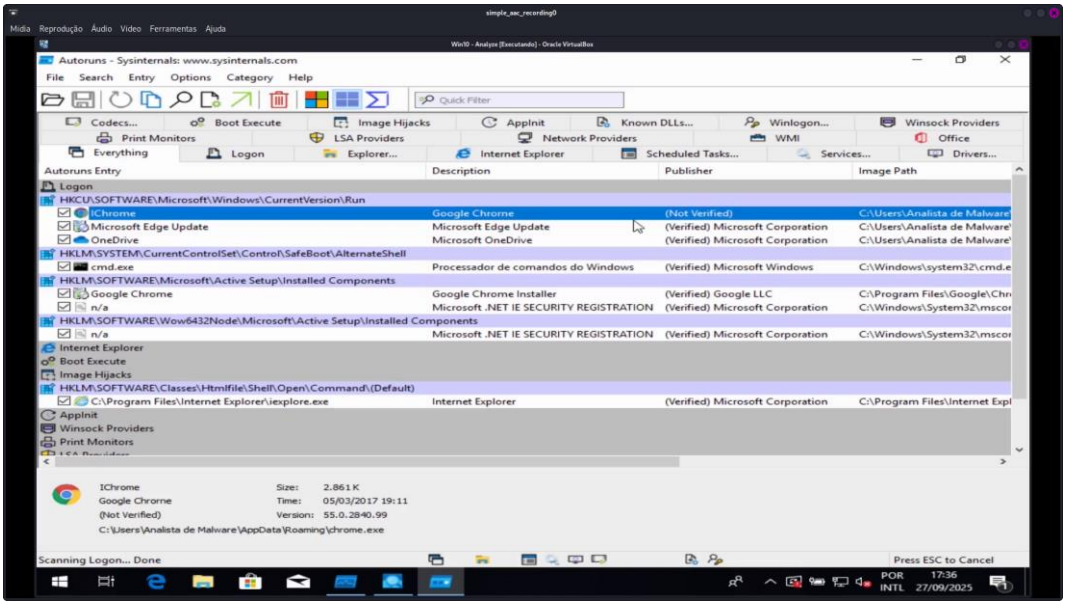


Chrome verídico e gchrome

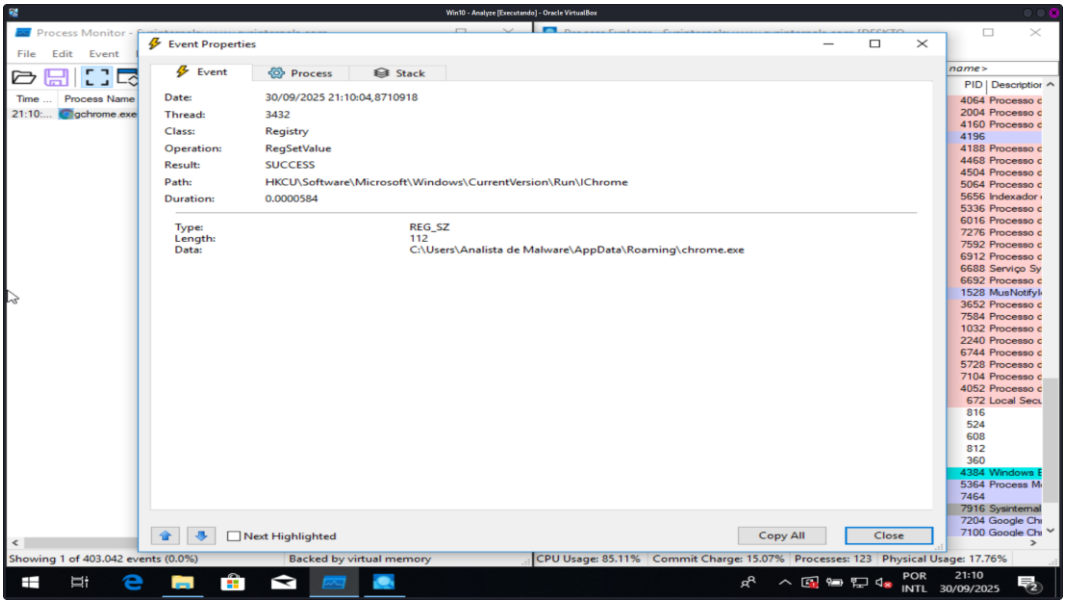
❖ **Persistência**

Após rodar por alguns segundo o autoruns foi detectado uma nova entrada de inicialização automática não verificada, chamada de **IChrome** e o que nos dá o

veredito que é o malware é seu caminho o mesmo do gchrome: C\:Users\AnalistadeMalware\AppData\Roaming\chrome.exe

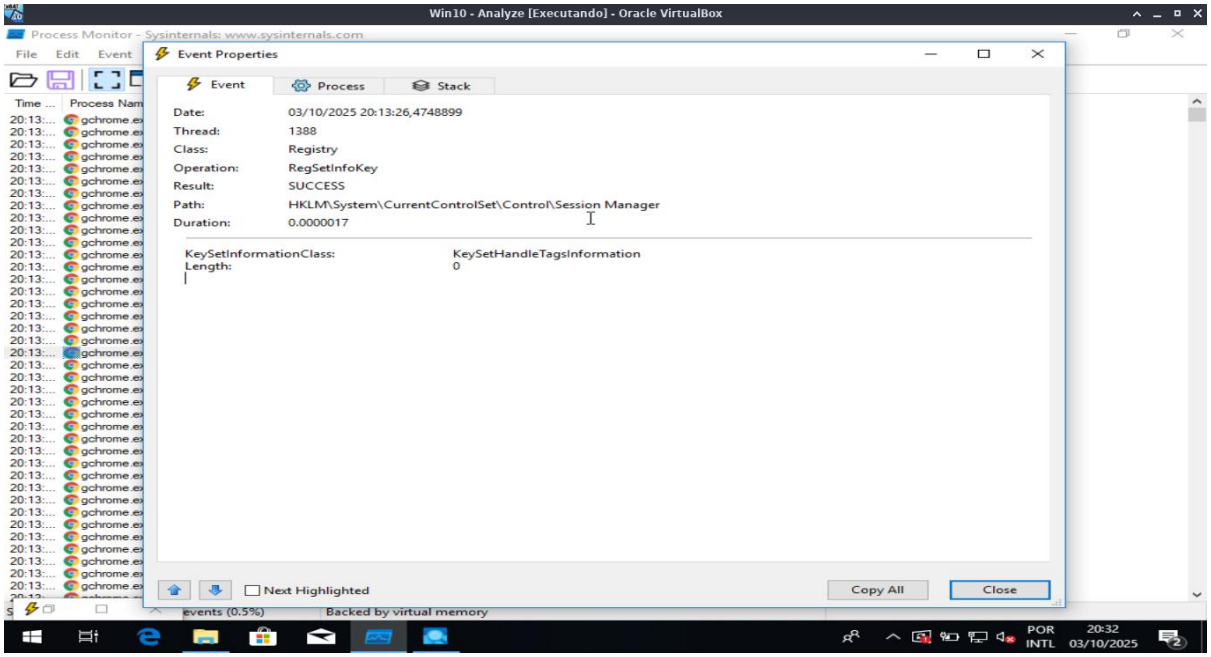


Persistência Identificada



IChrome Procmon

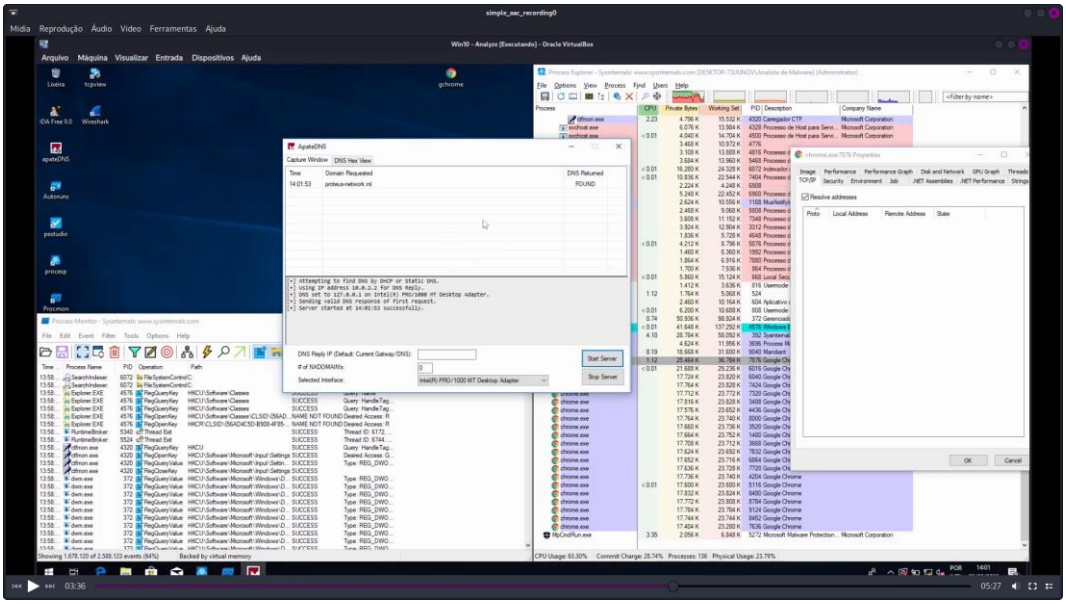
HKLM\System\CurrentControlSet\Control\Session Manager > Possível alteração em funções como BootExecute sendo uma possível tentativa de segunda persistência



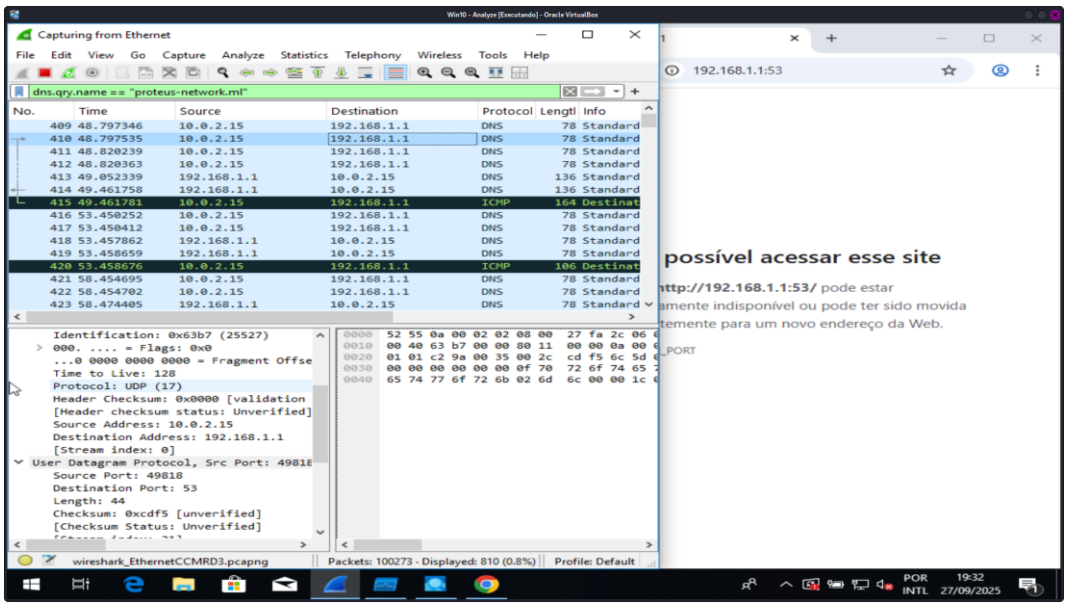
Session Manager

❖ Comunicação com domínio

Após a execução do gchrome.exe, dentro do apateDNS e Wire Shark foi possivel interceptar comunicação maliciosa, com seu domínio: **proteus-network.ml** essa descoberta pode ser validade com uma consulta dentro dos registros do Virus Total onde também é listado a esse domínio o malware.



Captura do domínio



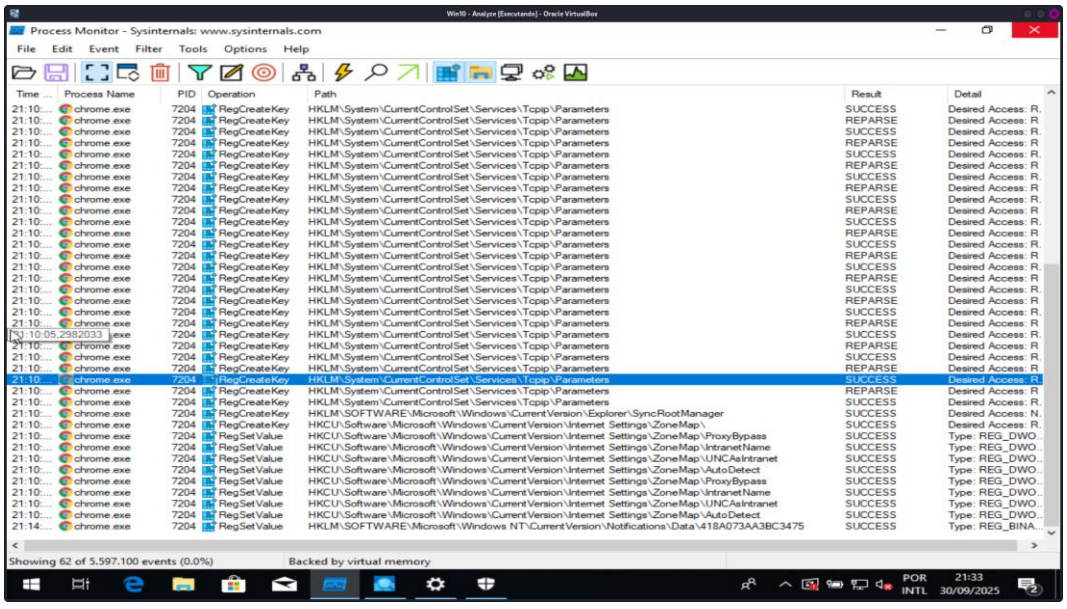
Captura no Wire Shark

- **Interação com chaves de registro**

  Interação com proxy e DNS > O malware fez várias escritas em registros visando os tais:

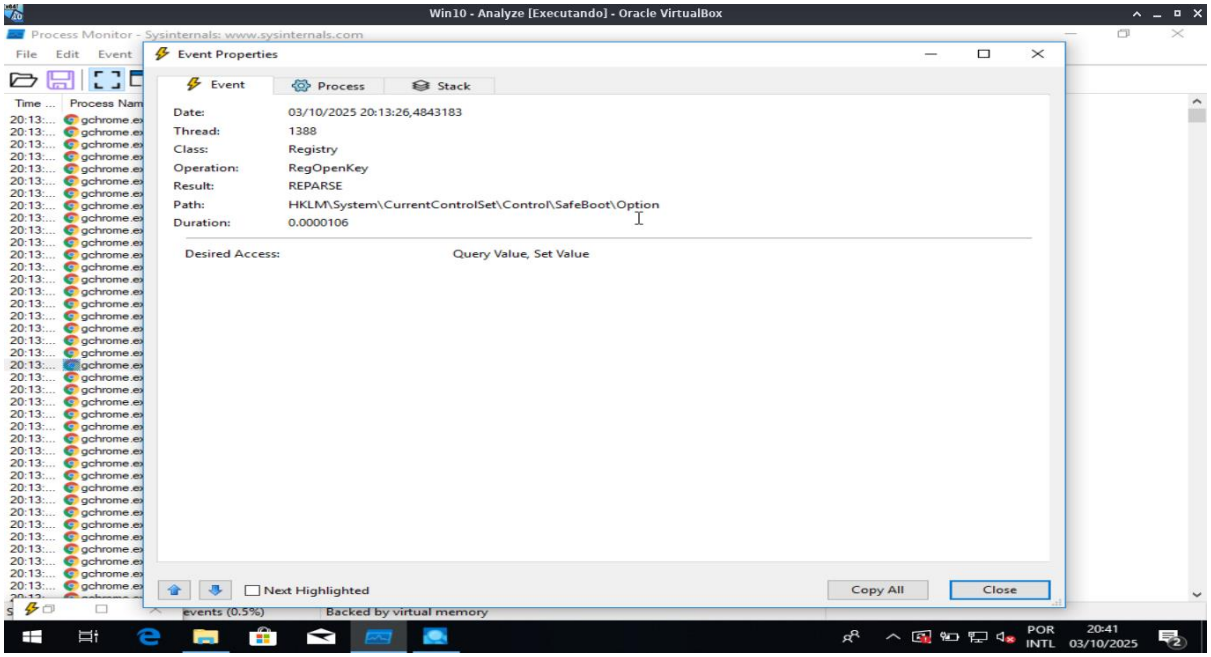
  Tcpip\Parameters > potencial hijack de DNS/tráfego

  HKCU\...\ZoneMap* > possivelmente utilizado para mapeamento de zonas (ProxyBypass/Intranet)



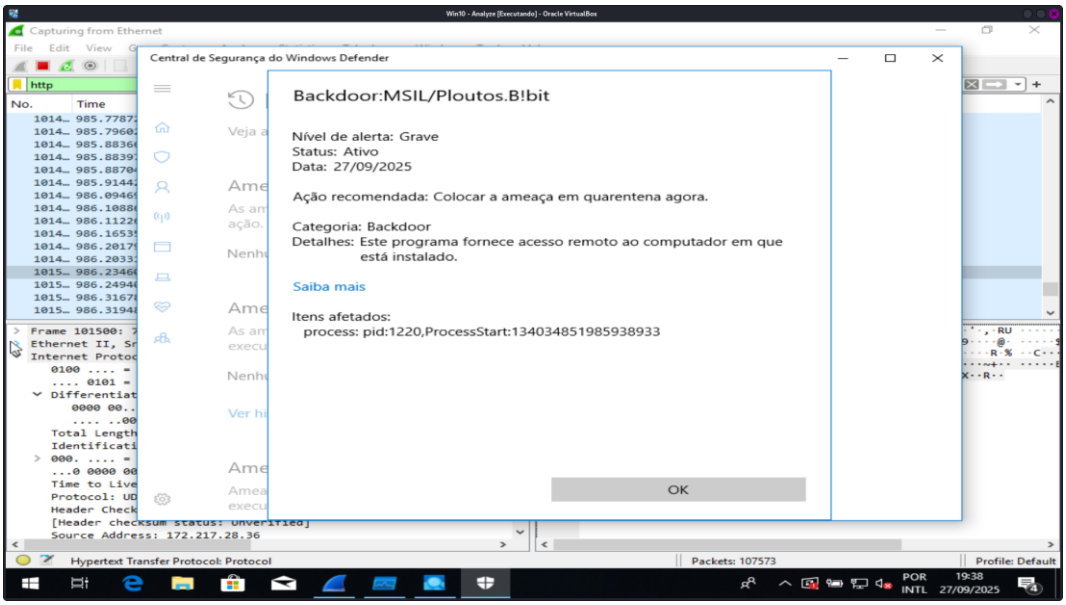
Interação com proxy e DNS

HKLM\System\CurrentControlSet\Control\SafeBoot\Option > Possivelmente criando ou verificando mecanismos para forçar a inicialização do sistema em um ambiente controlado pelo atacante.



Safeboot

- **Assinatura coletada:**
  Após a reinicialização do sistema, o **Windows Defender** identificou a presença de uma **backdoor**. A análise dos processos em execução revelou que o **PID associado** à detecção correspondia ao mesmo processo observado anteriormente no **Procmon**, referente ao **chrome.exe malicioso.**
  Esse achado nos confirma que a backdoor foi gerada e mantida pelo proteus, demonstrando sua capacidade de criação de um **canal de acesso remoto para o atacante**.



Assinatura coletada pelo Windows Defender

7. Mapeamento do MITRE ATT&CK

Tática (TTP)	Técnica	ID MITRE ATT&CK
Initial Access	Spearphishing Attachment	T1566.001
Initial Access	Drive-by Compromise	T1189
Execution	Command and Scripting Interpreter	T1059
Execution	Windows Command Shell	T1059.003
Persistence	Create or Modify System Process	T1543
Persistence	Registry Run Keys / Startup Folder	T1547.001
Privilege Escalation	Exploitation for Privilege Escalation	T1068
Defense Evasion	Obfuscated Files or Information	T1027
Defense Evasion	Masquerading	T1036
Credential Access	Input Capture	T1056
Credential Access	Brute Force	T1110
Discovery	System Information Discovery	T1082
Lateral Movement	Remote Services	T1021
Collection	Data from Local System	T1005
Command and Control	Application Layer Protocol	T1071
Exfiltration	Exfiltration Over C2 Channel	T1041

8. Impacto potencial

Após a instalação do malware, o sistema infectado poderá sofrer os seguintes impactos:

- **Roubo de credenciais**
- **Perda de dados sensíveis**
- **Persistência no sistema ->** dificultando a remoção
- **Execução remota de comandos**
- **Comprometimento da rede**
- **Aumento no consumo de processamento e memória ->** afetando o desempenho do sistema

9. Medidas de mitigação

Algumas medidas de mitigar esse malware podem ser:

- **Manter sistemas e softwares sempre atualizados**
- **Usar antivírus e soluções de endpoint**
- **Evitar abrir anexos e arquivos suspeitos**
- **Implementação de políticas de senhas fortes e MFA**
- **Monitorar tráfego de rede e atividades suspeitas**
- **Limitar privilégios de usuários e serviços**

10. Conclusão

O malware **Proteus** representa uma ameaça crítica a sistemas Windows, com capacidade de roubo de credenciais, persistência e execução remota. A adoção de medidas preventivas e boas práticas de segurança é essencial para reduzir os riscos e proteger dados e infraestrutura.

11. Referências

- MITRE ATT&CK: https://attack.mitre.org/
- TheZoo Malware Repository: https://github.com/ytisf/theZoo
- VirusTotal: https://www.virustotal.com/